THREAT-EXPOSURE-TTP

공격 표면·벡터·TTPs·측면이동·CTEM

연관 기출 · 126-1-12, 138-1-10, 138-3-5, 139-1-11

한눈에 이해

취약점 개수만 세지 않고, 실제로 어디로 들어와 어떤 권한과 경로로 중요한 업무에도 달할 수 있는 지 봅니다.

정의와 핵심 원리

공격 표면은 공격자가상호작용할 수 있는 노출 지점의집합이고공격 벡터는침투·피해를일으키는 경로·수단입니다. TTPs는 전술(목표)·기법(방법)·절차(구체수행)를구분하며 CTEM은 노출을 지속적으로발견·우선순위화·검증·개선하는운영 접근입니다.

• 네트워크스캐닝은호스트·포트·서비스·응답 특성등을 통해 노출을 파악합니다. 자산발견과취약점 진단은 다르며스캔결과는 방화벽·시간·네트워크 경로·인증 권한에 따라 달라집니다. 승인 범위·장치 영향·탐지 로그를 확인하고 산업 장치에 는 안전한 방법을 선택합니다.

• 측면이동은최초침입뒤다른 내부 시스템으로 접근·제어를확장하는행위입니다. 내부탐색·자격증명획득·원격서비스악용·권한확대등이 조합되며 정상SSH/RDP·계정을 써도악성목표가 가능합니다. 계정·단말·망 의이벤트를 연결해경로를 분석합니다.

• CTEM은 범위 설정 → 발견 → 우선순위화 → 검증 → 동원/개선의폐루프로설명할 수 있습니다. 자산중요도·실제도달가능성·공격가 능성·보완통제·업무피해를함께 봅니다. CVSS가 높은 항목만 나열하거나제품 설치로 완료했다고판단하지 않습니다.

구조·비교·판단

구분	핵심 원리	적용·한계
표면	노출 지점전체	외부·내부·신원·공급망
벡터	공격의 진입 경로	피싱·원격서비스등
TTP/CTEM	공격 행동언어/개선루프	관측·검증·책임자

적용 예제

인터넷 웹에서 급여 DB까지

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 노출웹취약점 → 과다서비스 계정 → 내부 DB 접근가 능가정

1. 노출과 업무자산을하나의경로로 모델링합니다.
2. 웹패치와계정 권한축소·망정책의 효과를 안전하게검증합니다.
3. 접속·토큰·원격실행 로그로 실제이동가능성을평가합니다.
4. 조치후동일경로를 재검증하고 새노출을 관측합니다.

결과·해석: 단일취약점점수보다중요업무까지 의실제 경로를 기준으로 개선합니다.

전제·주의: CTEM명칭의원저작자 방법론전문 미열람.다섯단계를 공식 의무 표준으로 쓰지않습니다.

답안 골격과 혼동 방지

용어구분 → TTP계층 → 스캐닝범위 → 측면이동경로 → CTEM루프

- 열린포트모두를취약점이라 하지 않습니다.
- TTP를IOC해시목록과 동일시하지 않습니다.

내용을 가리고 회상

1. 공격 표면과 벡터의차이는무엇입니까?
2. 정상계정을 쓰는측면이동은어떻게관측합니까?
3. 패치뒤재검증이 필요한 이유는무엇입니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- MITRE ATT&CK TA0008 Lateral Movement - MITRE; 최종수정 2025-08-11; 확인 2026-11-05.